

C L O U D O R A

Security Operations - Incident Response

INCIDENT RESPONSE REPORT

Payroll-Themed Credential Phishing Campaign - Two Accounts Compromised via a Lookalike Portal

Report ID	CLD-IR-0002
Related ticket	CLD-0002 - Reported phishing email impersonating Cloudora HR (payroll theme)
Classification	Training Use
Severity	P1 - Two staff accounts compromised, attacker actively signed in
Prepared by	Sai Nithish Sampath, Security Analyst (Simulated Engagement)
Investigation dates	25 – 26 August 2026
Report date	27 August 2026
Distribution	Cloudora IT Security, HR, Affected Staff (user comms)

About this document

Cloudora is a organisation created for training purposes. This report documents a simulated incident response exercise (“Payroll Phishing Campaign”) completed as part of independent SOC-analyst practice, working from raw phishing emails, Exchange Online message-trace logs, and Microsoft Entra ID sign-in logs in a lab environment.

The header analysis, KQL queries, findings, and conclusions in this document were produced first-hand from the raw data by the author. It is presented here in a consultancy-style format to demonstrate report-writing standards for a SOC/analyst portfolio, and is not a report of an actual security incident at a real company.

Table of Contents

1. Executive Summary	3
2. Incident Overview	3
3. Investigation Methodology	4
4. Detailed Timeline.....	4
5. Evidence and Analysis	5
6. Indicators of Compromise	8
7. MITRE ATT&CK Mapping.....	9
8. Detection Logic	9
9. Containment Actions.....	10
10. Root Cause Analysis	10
11. Impact Assessment.....	10
12. Lessons Learned.....	11
13. Recommendations	11
Appendix A - Full KQL Query Pack.....	12
Appendix B - Population Lists	14
Appendix C - User Communications Drafts	15
References	15

1. Executive Summary

On 25 August 2026, an external attacker sent a payroll-themed phishing campaign to 40 Cloudora staff, impersonating Cloudora HR and asking recipients to 'confirm their payroll details' on a lookalike website. This report documents the resulting investigation into the reported email, Exchange Online message-trace data, and Microsoft Entra ID sign-in logs, the confirmed compromises, containment actions, and recommendations arising from ticket CLD-0002.

The campaign used two message variants. Variant A forged the genuine payroll@cloudora.io address and failed SPF, DKIM and DMARC outright. Variant B was sent from the attacker's own lookalike domain, cloudora-hr-portal.example, and passed all three authentication checks - for that lookalike domain, not for Cloudora. Of 40 targeted staff, 36 received the email in their inbox (4 were fully protected by Exchange Online Protection quarantine), 6 clicked the link, and 2 entered their credentials.

Both compromised accounts - freya.lynn@cloudora.io and ryan.boyd@cloudora.io - were signed into the same afternoon from an IP address in Amsterdam, Netherlands, on a device neither had used before, confirming the attacker used the harvested passwords to log in. The compromise was caught the same morning after a staff member forwarded the email to the SOC. Both accounts were contained, the attacker's infrastructure was blocked, and the phishing messages were purged from remaining mailboxes. A marketing newsletter reported alongside the phish was investigated and confirmed legitimate. No evidence of fraudulent payment or data exfiltration was found in the available log data.

Headline findings

2 accounts confirmed compromised: freya.lynn@cloudora.io and ryan.boyd@cloudora.io, both via first-try successful sign-ins from attacker infrastructure - no failed attempts, unlike a password-spray compromise. 40 staff targeted; 36 received the phish, 6 clicked, 2 submitted credentials, 4 were fully protected by Exchange Online Protection.

The campaign used a fail-authentication spoof (Variant A) and a pass-authentication lookalike domain (Variant B) - passing SPF/DKIM/DMARC does not mean an email is safe.

A reported Mailchimp newsletter was investigated and cleared as a genuine Cloudora send, correctly separated from the two malicious variants.

Both accounts contained, attacker infrastructure blocked, and no further attacker activity observed after containment.

2. Incident Overview

2.1 Classification

Field	Detail
Incident type	Credential phishing - payroll-themed campaign leading to account compromise
Related ticket	CLD-0002 - reported phishing email impersonating Cloudora HR
Severity	P1 - two staff accounts compromised, attacker actively signed in
Affected tenant	Cloudora (Microsoft 365 / Entra ID / Exchange Online)
Detection source	Staff report (James Holt forwarded the email to the SOC)

Field	Detail
Reporting analyst	Sai Nithish Sampath
Data sources reviewed	6 reported .eml files, Exchange Online message trace (CloudoraMsgTrace_CL), Entra ID sign-in logs (CloudoraSignIn_CL)
Investigation window	25 August 2026 campaign and response; report issued 27 August 2026

2.2 Systems and Accounts in Scope

The investigation covered Cloudora's Exchange Online mail flow and the full Microsoft 365 / Entra ID tenant. Forty user accounts appear in the affected campaign; two were confirmed compromised, four clicked the link without entering credentials, thirty received the email without clicking, and four were fully protected by mail-gateway filtering.

3. Investigation Methodology

This investigation ran in two halves. The first triaged the reported email itself, using header and authentication analysis - no log platform required. The second scoped the campaign across the tenant using KQL against two log tables (CloudoraMsgTrace_CL, CloudoraSignIn_CL) in Azure Data Explorer. All timestamps in this report are UTC.

1. **Triage the reported email** - Open the forwarded and clean copies of the phish as raw text and read the headers - never in a mail client - starting with the From address, not the display name an attacker fully controls.
2. **Dissect authentication results** - Read SPF, DKIM and DMARC verdicts, and the Received chain from the bottom up to find the true sending infrastructure.
3. **Analyse the URL and infrastructure** - Read the actual link target, not the button text, and compare sending IPs across every reported copy to map the campaign's infrastructure.
4. **Enrich the indicators** - Note what a VirusTotal / AbuseIPDB lookup on the domain and sending IPs would be expected to show, as corroborating - not primary - evidence.
5. **Verdict the false positive** - Run the identical checklist against the reported newsletter, and show why it passes authentication for the genuine cloudora.io brand rather than a lookalike.
6. **Scope the campaign in KQL** - Query message-trace data for delivery, quarantine, clicks and credential submissions across all 40 targeted accounts.
7. **Confirm compromise and pivot** - Pull sign-ins for every credential submitter, then pivot on the attacker's login IP to confirm the full set of compromised accounts.
8. **Contain and verify** - Execute containment on both accounts, then re-run the scoping and pivot queries to confirm no further attacker activity.

4. Detailed Timeline

All times UTC, reconstructed from message-trace and sign-in log timestamps, and the reported .eml headers.

Time (UTC)	Event	Source
06:58	Legitimate Cloudora newsletter delivered via Mailchimp (later reported alongside the phish, cleared as false positive)	Msg trace

Time (UTC)	Event	Source
07:54 – 08:20	Variant A, wave 1, sent from 198.18.44.10 spoofing payroll@cloudora.io; SPF/DKIM/DMARC fail; some copies quarantined by EOP, some delivered	Msg trace
08:35 – 08:50	Variant A wave 2 from 198.18.44.23, and Variant B from 198.18.51.7 using lookalike domain cloudora-hr-portal.example (auth passes for the fake domain)	Msg trace
08:39:03	seth.lane clicks the Variant A link; credentials not submitted	Msg trace
08:47:12	freya.lynn clicks Variant A and SUBMITS credentials	Msg trace
09:05:44	ryan.boyd clicks Variant B and SUBMITS credentials	Msg trace
09:11	james.holt forwards the phish to the SOC; ticket CLD-0002 raised, investigation starts	Ticket
09:58 / 10:12 / 11:47	hugo.marsh, chloe.price and dina.said click the link; none submit credentials	Msg trace
10:34:20	Attacker signs in as freya.lynn from 198.18.7.200 (Amsterdam, NL) on Windows 11 / Chrome - harvested credential used; Outlook Web 10:36, SharePoint 10:41	Sign-in log
13:22:05	Attacker signs in as ryan.boyd from 198.18.7.200 (Amsterdam) - second account used; Outlook Web 13:25	Sign-in log
~14:00	Containment executed on both accounts (see Section 9)	Response

5. Evidence and Analysis

5.1 Header analysis - Variant A (spoofed Cloudora address)

Source: 01_phishing_payroll_variantA_reported.eml and 05_phishing_payroll_variantA_forwarded.eml.

The From address, payroll@cloudora.io, claims to be Cloudora - but the message cannot prove it. The Authentication-Results header shows spf=fail, dkim=fail, and dmarc=fail action=quarantine, with Microsoft's composite spoof verdict compauth=fail reason=001. Reading the Received chain from the bottom up shows the true origin: mail.cloudora-hr-portal.example at 198.18.44.23 (and, on a separate copy of the same variant, 198.18.44.10 - two relays in the same /24 block). The Reply-To header points to hr-support@cloudora-hr-portal.example, meaning a reply would leave the company straight to the attacker, despite the From address appearing internal.

Check	Result	Verdict
From address	payroll@cloudora.io (claimed)	Cannot be trusted - attacker-controlled field
SPF / DKIM / DMARC	fail / fail / fail (quarantine), compauth=fail reason=001	Fails authentication for cloudora.io
True origin (Received chain)	mail.cloudora-hr-portal.example, 198.18.44.10 / 198.18.44.23	External, not Cloudora infrastructure
Reply-To	hr-support@cloudora-hr-portal.example	Mismatched - replies leave the company
Link target	https://cloudora-hr-portal.example/payroll/login	Lookalike domain, not cloudora.io

Verdict: PHISH. Spoofed sender, all authentication checks fail, external origin, mismatched Reply-To, and a credential-harvesting link on a lookalike domain.

5.2 Header analysis - Variant B (the pass-authentication trap)

Source: 02_phishing_payroll_variantB.eml.

Variant B is sent from the attacker's own domain, cloudora-hr-portal.example, at 198.18.51.7. Because the message genuinely originates from that domain, SPF, DKIM and DMARC all PASS - but they pass for cloudora-hr-portal.example, not for cloudora.io. This is the central analytic trap of the investigation: authentication only proves which domain sent a message, not whether that domain is trustworthy. A green authentication result on a lookalike domain is still a phish. The link (login.cloudora-hr-portal.example/verify) leads to the same credential-harvesting infrastructure as Variant A.

Verdict: PHISH, despite passing authentication - the domain being authenticated is not Cloudora's.

5.3 False positive clearance - Mailchimp newsletter

Source: 03_benign_mailchimp_newsletter.eml, forwarded by adam.clark alongside the phishing report.

The 'Cloudora Monthly' newsletter is sent from news@cloudora.io. Authentication-Results shows spf=pass, dkim=pass for both header.d=cloudora.io and header.d=mcsv.net (Mailchimp, Cloudora's authorised sending service), and dmarc=pass action=none with alignment to cloudora.io. It carries a valid one-click List-Unsubscribe header and its links resolve to Cloudora's genuine list-manage domain. Unlike Variant B, its authentication aligns to the real Cloudora brand, not a lookalike - the distinguishing test between a genuine pass and a phishing pass.

Verdict: LEGITIMATE. Cleared with evidence so it is not re-investigated.

5.4 Campaign delivery scope

Query: message-trace delivery events grouped by campaign, sender IP, and authentication result.

Campaign	Sender IP	SPF / DKIM / DMARC	Delivered	Quarantined
PayrollPhish-A	198.18.44.10	fail / fail / fail	25	7
PayrollPhish-A	198.18.44.23	fail / fail / fail	8	0
PayrollPhish-B	198.18.51.7	pass / pass / pass (lookalike domain)	21	0

Forty distinct accounts were targeted. Thirty-six had at least one copy delivered to the inbox; four (emma.hayes, maya.chen, nina.cole, ruth.dean) had every copy quarantined by Exchange Online Protection and never saw the message - all against the fail-authentication Variant A, which EOP's own checks were able to catch. Variant B's passing authentication let it slip through to every one of its 21 targets.

5.5 Click and credential-submission analysis

Query: message-trace click events, oldest first.

Time (UTC)	Recipient	Campaign	Credentials submitted?
08:39:03	seth.lane@cloudora.io	PayrollPhish-A	No
08:47:12	freya.lynn@cloudora.io	PayrollPhish-A	Yes

Time (UTC)	Recipient	Campaign	Credentials submitted?
09:05:44	ryan.boyd@cloudora.io	PayrollPhish-B	Yes
09:58:50	hugo.marsh@cloudora.io	PayrollPhish-B	No
10:12:37	chloe.price@cloudora.io	PayrollPhish-A	No
11:47:19	dina.said@cloudora.io	PayrollPhish-A	No

Six of the 36 delivered-to recipients clicked the link. Two - freya.lynn and ryan.boyd - submitted credentials on the harvesting page and are treated as compromised; their passwords must be assumed known to the attacker. The other four clicked but did not enter anything, so their passwords are not confirmed lost, though reaching the harvesting page still places them at elevated risk pending a precautionary reset.

5.6 Confirmed compromise - freya.lynn@cloudora.io

Query: sign-ins for the credential submitters on the incident day.

Time (UTC)	App	IP	City / Country	Device
08:29	Outlook Web App	198.51.100.20	Manchester, United Kingdom	iOS 17
10:34	Microsoft 365	198.18.7.200	Amsterdam, Netherlands	Windows 11 / Chrome
10:36	Outlook Web App	198.18.7.200	Amsterdam, Netherlands	Windows 11 / Chrome
10:41	SharePoint Online	198.18.7.200	Amsterdam, Netherlands	Windows 11 / Chrome
13:38	Microsoft 365	198.51.100.20	Manchester, United Kingdom	iOS 17

Freya's genuine activity is from Manchester on her iPhone. At 10:34 - roughly two hours after she submitted her password - a successful sign-in appears from 198.18.7.200 in Amsterdam on a Windows 11 / Chrome device she has never used, followed by Outlook Web and SharePoint access. This is impossible travel with no supporting journey, and it is the harvested credential being used by the attacker (T1078). She returns to her genuine Manchester device at 13:38, confirming the account holder herself never travelled.

5.7 Confirmed compromise - ryan.boyd@cloudora.io

Query: sign-in timeline for the second account, found by pivoting on the attacker's IP (see Section 5.8).

Time (UTC)	App	IP	City / Country	Device	Result
08:12	Outlook Web App	203.0.113.10	London, United Kingdom	iOS 17	Genuine
13:22	Microsoft 365	198.18.7.200	Amsterdam, Netherlands	Windows 11 / Chrome	Attacker
13:25	Outlook Web App	198.18.7.200	Amsterdam, Netherlands	Windows 11 / Chrome	Attacker
13:43	Outlook Web App	203.0.113.10	London, United Kingdom	iOS 17	Genuine

Ryan works normally from London on his iPhone, submits credentials to Variant B at 09:05, and at 13:22 the attacker signs in from the same Amsterdam IP used against Freya, on the same unfamiliar Windows/Chrome device - an eighteen-minute gap either side of his own genuine London sign-ins, which is impossible travel. Notably, both compromises show a clean first-try successful login with no failed attempts beforehand - the

fingerprint of a phished password being used directly, in contrast to the failed-attempts-then-success pattern of a password-spray compromise.

5.8 Scope confirmation - pivoting on the attacker IP

Query: every successful sign-in from 198.18.7.200 across the tenant.

Pivoting on the Amsterdam login IP, rather than assuming Freya was the only victim, returns exactly two accounts: freya.lynn@cloudora.io and ryan.boyd@cloudora.io. No other account shows a successful sign-in from this address, confirming the compromise is limited to the two credential submitters.

5.9 Population tiering

Sorting all 40 targeted accounts into the correct risk tier is central to a proportionate response. Full lists are in Appendix B.

Tier	Count	Action
Confirmed compromised (submitted credentials, attacker signed in)	2	Full containment (Section 9)
Clicked, no credentials submitted	4	Precautionary password reset, direct check-in
Received, did not click (near-miss)	30	General awareness communication
Targeted, fully quarantined by EOP (never saw it)	4	Awareness note only, no action needed

6. Indicators of Compromise

Type	Indicator	Context
Sending IP	198.18.44.10	Variant A relay (wave 1); spoofs payroll@cloudora.io, fails all authentication
Sending IP	198.18.44.23	Variant A relay (wave 2); same spoofing pattern
Sending IP	198.18.51.7	Variant B relay; sends from the lookalike domain and passes authentication for it
Login / harvest IP	198.18.7.200	Amsterdam - used to sign in to both compromised accounts with harvested credentials
Lookalike domain	cloudora-hr-portal.example	Attacker infrastructure; hosts the harvesting page and Variant B's Reply-To / From
Malicious URL	hxxps://cloudora-hr-portal[.]example/payroll/login	Credential-harvesting page (Variant A)
Malicious URL	hxxps://login[.]cloudora-hr-portal[.]example/verify	Credential-harvesting page (Variant B)
Spoofed sender	payroll@cloudora.io	Forged address used in Variant A
Device / User-Agent	Windows 11, Chrome	Attacker session fingerprint, never seen on either victim account before
Compromised account	freya.lynn@cloudora.io	Confirmed compromise

Type	Indicator	Context
Compromised account	ryan.boyd@cloudora.io	Confirmed compromise

7. MITRE ATT&CK Mapping

Tactic	Technique	Observed behaviour
Initial Access	T1566.002 - Phishing: Spearphishing Link	Payroll-themed email with a credential-harvesting link sent to 40 staff across two variants
Initial Access	T1078 - Valid Accounts	Attacker signed in to both accounts using harvested passwords, first attempt succeeding each time
Defense Evasion	T1036.005 - Match Legitimate Name or Location	Lookalike domain cloudora-hr-portal.example and spoofed payroll@cloudora.io display name
Credential Access	T1589 / T1598 - Credential harvesting via a lookalike portal	Fake payroll login page collected two staff members' passwords
Collection	T1114 - Email Collection (post-access)	Outlook Web and SharePoint accessed from both compromised sessions

8. Detection Logic

The queries below (KQL, Microsoft Sentinel / Azure Data Explorer syntax) were used during the investigation. Full text of every query is in Appendix A. Task 4 of the exercise asks for one new detection rule; it is included as 8.3 below.

8.1 Credential submitters signing in from new infrastructure

```
let CredVictims = CloudoraMsgTrace_CL
| where EventType == "Click" and CredentialsSubmitted == "Yes"
| distinct RecipientAddress;
CloudoraSignIn_CL
| where UserPrincipalName in (CredVictims)
| where ResultType == "0"
```

Surfaces every successful sign-in belonging to an account that is known to have submitted credentials to a phishing page - the direct link between the click event and the account-takeover step.

8.2 Attacker-IP pivot to catch every victim, not just the first

```
CloudoraSignIn_CL
| where IPAddress startswith "198.18.7." and ResultType == "0"
| summarize FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated),
    Apps=make_set(AppDisplayName) by UserPrincipalName, IPAddress, Country
```

Once one attacker IP is known, this rule finds every account that IP touched - the query that turned a one-victim assumption into two confirmed compromises in this investigation.

8.3 Standing rule (Task 4) - new-country sign-in shortly after a phishing click

```
let RecentClickers = CloudoraMsgTrace_CL
| where EventType == "Click"
| project RecipientAddress, ClickTime = TimeGenerated;
```

```
CloudoraSignIn_CL
| where ResultType == "0"
| join kind=inner RecentClickers on $left.UserPrincipalName == $right.RecipientAddress
| where TimeGenerated between (ClickTime .. ClickTime + 6h)
| where Country != "United Kingdom"
```

This rule correlates a successful sign-in directly to a phishing-link click by the same account within a 6-hour window, and flags it if the sign-in's country doesn't match Cloudora's normal baseline (United Kingdom). A 6-hour threshold is chosen because in this incident both attacker logins followed their respective clicks by under 4 hours - wide enough to catch a same-day credential reuse, tight enough to stay meaningfully correlated to the click rather than matching unrelated later activity. Deployed as a standing rule, this would have flagged Freya's compromise at 10:34, roughly four and a quarter hours before the phish was actually reported and over five hours before this investigation began.

9. Containment Actions

- Revoked all active sessions and refresh tokens for freya.lynn@cloudora.io and ryan.boyd@cloudora.io - done first, since a password reset alone leaves an existing attacker session alive.
- Force-reset credentials for both compromised accounts.
- Required and re-registered MFA on both accounts - both fell to a password alone, so MFA is the control that stops a harvested password being sufficient next time.
- Blocked the attacker infrastructure at the mail gateway and web proxy: sending relays 198.18.44.10, 198.18.44.23, 198.18.51.7; login IP 198.18.7.200; and the domain cloudora-hr-portal.example and its subdomains.
- Purged the delivered phishing messages from every remaining mailbox (zero-hour auto purge / soft delete).
- Issued a precautionary password reset to the four accounts that clicked but did not submit credentials.
- Re-ran the credential-submitter sign-in query and the attacker-IP pivot after containment; confirmed no further activity from 198.18.7.200 or the sending infrastructure.

10. Root Cause Analysis

The root cause was two staff members entering their credentials into a convincing lookalike payroll portal, following a well-crafted campaign that combined urgency ('before 5pm'), brand impersonation, and - for Variant B - technically valid authentication for the attacker's own domain, which would not have raised any automated red flag based on SPF/DKIM/DMARC alone. A contributing factor was that Exchange Online Protection could only catch the fail-authentication Variant A; Variant B's legitimately-passing authentication let all 21 of its copies straight through, which is why 21 of the 36 delivered messages came from the harder-to-catch variant. There was no standing detection correlating a phishing click to a subsequent sign-in, so the compromise was only caught because a staff member reported the email - not through automated detection - roughly two hours after the attacker had already used the first stolen credential.

11. Impact Assessment

Area	Assessment
Confidentiality	Attacker had Outlook Web access on both accounts, and SharePoint access on Freya's, for up to ~3.5 hours before containment

Area	Assessment
Integrity	No evidence of altered records, forwarding rules, or other configuration changes in the available log data
Availability	No disruption to Cloudora services
Financial	No confirmed fraudulent payment identified; this was a credential-harvesting campaign without an observed BEC follow-through in the available data
Reputational	Limited - caught and contained the same morning following staff reporting, before any external communications were sent from either account, based on available data
Workforce	6 staff directly affected (2 compromised, 4 elevated-risk); 34 further staff required awareness or reassurance communication

12. Lessons Learned

- ‘Passed authentication’ is not a synonym for ‘safe’ - Variant B's passing SPF/DKIM/DMARC for its own lookalike domain is the clearest evidence in this incident that the analyst must always ask ‘passed for which domain’, not just ‘did it pass’.
- The compromise was caught by a staff member reporting the email, not by automated detection - the new correlation rule in Section 8.3 closes that gap for future incidents.
- Pivoting on the attacker's login IP, rather than stopping at the first confirmed victim, is what surfaced the second compromised account; the same discipline that mattered in the CEO account-takeover investigation applies here.
- Sorting the affected population into the right tier (compromised / clicked-no-creds / near-miss / protected) kept the response proportionate - a blanket reset across all 40 targeted accounts would have been unnecessary and disruptive.

13. Recommendations

13.1 Detective controls

- Deploy the new-country-sign-in-after-click correlation rule in Section 8.3 as a standing Sentinel analytics rule.
- Alert on any successful sign-in immediately following a recorded credential submission on a tracked phishing/training link.
- Extend EOP detection to catch spoofed-brand lookalike domains registered close to the campaign date, not only failed SPF/DKIM/DMARC.

13.2 Preventive controls

- Require phishing-resistant MFA (e.g. FIDO2 security keys) tenant-wide, so a harvested password alone is insufficient.
- Register lookalike-domain monitoring for cloudora.io variants (typosquats, hyphenated lookalikes) to catch infrastructure before a campaign launches.
- Apply Safe Links / URL rewriting so clicks on suspicious external links are intercepted before reaching a live credential-harvesting page.

13.3 Organisational

- Send the near-miss and clicked-but-no-credentials communications drafted in Appendix C.
- Deliver targeted phishing-recognition training referencing this campaign's 'pass ≠ safe' lesson, focused on payroll and finance-themed lures specifically.
- Review the SLA for staff-reported phishing tickets - in this case, roughly two hours elapsed between the first credential theft and the report reaching the SOC.

Appendix A - Full KQL Query Pack

Reproduced in full below for reference and reuse. Table names: CloudoraMsgTrace_CL, CloudoraSignIn_CL. All timestamps UTC.

A.1 Sanity check

```
CloudoraMsgTrace_CL
| count
```

```
CloudoraSignIn_CL
| count
```

A.2 Campaign scope - what landed, from where, did it pass auth

```
CloudoraMsgTrace_CL
| where EventType == "Delivery"
| summarize Messages=count(), Recipients=dcount(RecipientAddress)
    by Campaign, SenderAddress, SenderIP, SPFResult, DKIMResult, DMARCRresult,
DeliveryAction
| order by Campaign asc, SenderIP asc
```

A.3 Delivered-to vs. protected by EOP

```
CloudoraMsgTrace_CL
| where EventType == "Delivery" and DeliveryAction == "Delivered"
| distinct RecipientAddress

let DeliveredTo = CloudoraMsgTrace_CL
    | where EventType == "Delivery" and DeliveryAction == "Delivered"
    | distinct RecipientAddress;
CloudoraMsgTrace_CL
| where EventType == "Delivery" and DeliveryAction == "Quarantined"
| where RecipientAddress !in (DeliveredTo)
| distinct RecipientAddress
```

A.4 Clicks and credential submissions

```
CloudoraMsgTrace_CL
| where EventType == "Click"
| project TimeGenerated, RecipientAddress, Campaign, Url, ClickIP, CredentialsSubmitted
| order by TimeGenerated asc

CloudoraMsgTrace_CL
| where EventType == "Click" and CredentialsSubmitted == "Yes"
| project TimeGenerated, RecipientAddress, Campaign, Url, ClickIP
| order by TimeGenerated asc
```

A.5 Did a submitted credential get used?

```
let CredVictims = CloudoraMsgTrace_CL
    | where EventType == "Click" and CredentialsSubmitted == "Yes"
    | distinct RecipientAddress;
CloudoraSignIn_CL
| where UserPrincipalName in (CredVictims)
| where ResultType == "0"
```

```
| project TimeGenerated, UserPrincipalName, AppDisplayName, IPAddress, City, Country,
DeviceOS, Browser
| order by UserPrincipalName asc, TimeGenerated asc
```

A.6 Pivot on the attacker IP - is anyone else compromised?

```
CloudoraSignIn_CL
| where IPAddress startswith "198.18.7." and ResultType == "0"
| summarize FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated),
              Apps=make_set(AppDisplayName) by UserPrincipalName, IPAddress, Country
| order by FirstSeen asc
```

A.7 Near-miss list (Task 2) - delivered-to, minus clickers

```
let Clickers = CloudoraMsgTrace_CL
    | where EventType == "Click"
    | distinct RecipientAddress;
CloudoraMsgTrace_CL
| where EventType == "Delivery" and DeliveryAction == "Delivered"
| distinct RecipientAddress
| where RecipientAddress !in (Clickers)
| order by RecipientAddress asc
```

A.8 Clicked but did not submit credentials

```
CloudoraMsgTrace_CL
| where EventType == "Click" and CredentialsSubmitted == "No"
| distinct RecipientAddress
```

A.9 Standing detection (Task 4) - new-country sign-in shortly after a click

```
let RecentClickers = CloudoraMsgTrace_CL
    | where EventType == "Click"
    | project RecipientAddress, ClickTime = TimeGenerated;
CloudoraSignIn_CL
| where ResultType == "0"
| join kind=inner RecentClickers on $left.UserPrincipalName == $right.RecipientAddress
| where TimeGenerated between (ClickTime .. ClickTime + 6h)
| where Country != "United Kingdom"
```

Appendix B - Population Lists

B.1 Confirmed compromised (2)

freya.lynn@cloudora.io *, ryan.boyd@cloudora.io * - both submitted credentials and were subsequently signed into by the attacker.

B.2 Clicked, credentials not submitted - precautionary reset (4)

seth.lane@cloudora.io, chloe.price@cloudora.io, hugo.marsh@cloudora.io, dina.said@cloudora.io

B.3 Received, did not click - near-miss / general awareness (30)

Account	Account
adam.clark@cloudora.io	jude.ross@cloudora.io
alba.vega@cloudora.io	kian.patel@cloudora.io
amelia.frost@cloudora.io	leah.stone@cloudora.io
aria.reid@cloudora.io	lena.voss@cloudora.io
arjun.mehta@cloudora.io	liam.doyle@cloudora.io
cole.burke@cloudora.io	lucas.ford@cloudora.io
daniel.reeve@cloudora.io	mira.shah@cloudora.io
dean.page@cloudora.io	noah.bishop@cloudora.io
ethan.wells@cloudora.io	olivia.kaur@cloudora.io
felix.hart@cloudora.io	omar.farah@cloudora.io
finn.gale@cloudora.io	priya.nair@cloudora.io
gwen.muir@cloudora.io	rhys.owen@cloudora.io
isla.grant@cloudora.io	sofia.marino@cloudora.io
james.holt@cloudora.io	tara.kemp@cloudora.io
joel.kerr@cloudora.io	zara.aziz@cloudora.io

B.4 Targeted, fully protected by EOP - no action beyond awareness (4)

emma.hayes@cloudora.io, maya.chen@cloudora.io, nina.cole@cloudora.io, ruth.dean@cloudora.io - every copy sent to these accounts was quarantined; none reached the inbox.

Appendix C - User Communications Drafts (Task 3)

C.1 Near-miss group (received, did not click) - 30 recipients

Subject: Heads up: a fake 'payroll update' email is going around

Hi all,

This morning some of us received an email claiming to be from Cloudora HR, with the subject 'Payroll update: action required', asking you to confirm your payroll details on a website. It is not from us. It is a phishing email and we have removed it from mailboxes.

You do not need to do anything. If you did click the link or entered any details, tell IT security straight away - you will not be in trouble, we just need to help you quickly.

A reminder: Cloudora will never ask you to confirm your password or bank details through an email link. Payslips and bank details live in the HR portal, which you reach by signing in normally at myhr.cloudora.io.

Thanks for staying sharp,
Cloudora IT Security

C.2 Clicked-but-no-credentials group - 4 recipients, sent individually

Direct, individual message

You clicked a link in a phishing email this morning. As a precaution we are resetting your password now and you will be asked to sign in again.

You do not appear to have entered any details, which is good. Please do not enter your Cloudora password on any site you reached from that email, and let us know if you did.

References

- MITRE ATT&CK®, Enterprise Matrix - attack.mitre.org
- Microsoft Learn - Exchange Online message trace and Microsoft Entra ID sign-in log schema reference
- Microsoft Sentinel / Azure Data Explorer Kusto Query Language (KQL) documentation